

Actividad 04

Una página demasiado convincente

Análisis de una simulación de ingeniería social mediante Social-Engineer Toolkit (SET) orientada a la captura de credenciales.

Mtro. Servando López Contreras

Informe realizado por:

181583 Angel Aaron Acuña Quezada

Contents

Introducción	3
Objetivo de la actividad	3
Descripción del escenario	3
Configuración del laboratorio	4
Evidencias y descripción del funcionamiento	4
Explicación del flujo de información	5
Controles de Seguridad propuestos	6
Soluciones propuestas	6
Conclusión	7
Referencias	7

Introducción

Usualmente, cuando un atacante busca comprometer una organización, no comienza vulnerando directamente la infraestructura como se muestra en la ficción. Todo ataque inicia con una fase de reconocimiento, y si la red corporativa cuenta con un sistema de seguridad robusto, estos suelen presentar un muro difícil de penetrar. Es aquí donde entra el eslabón más vulnerable de cualquier sistema: **el factor humano**.

A este tipo de vulneración se le conoce como **ingeniería social**, definida como el arte de la manipulación psicológica. Los atacantes utilizan señuelos basados en el sentido de urgencia, la recompensa ('Felicidades, ha ganado un dispositivo móvil, haga clic aquí') o incluso la coerción y el miedo ('Aviso urgente: Su actividad web está siendo investigada por autoridades federales'). Aunque los mensajes suelen basarse en plantillas genéricas, representan un riesgo crítico; basta con que un solo empleado sea caiga en el engaño para que toda la red interna de la empresa termine comprometida. Esta práctica permite comprender la anatomía de una campaña de *phishing* básica, subrayando la importancia de implementar controles técnicos preventivos y capacitar continuamente a los usuarios frente a este tipo de amenazas.

Objetivo de la actividad

Implementar y analizar, en un entorno controlado, una simulación de ingeniería social mediante Social-Engineer Toolkit (SET), utilizando una página web ficticia para comprender el funcionamiento de una técnica de captura de información y reconocer los elementos que permiten identificar un intento de phishing.

Descripción del escenario

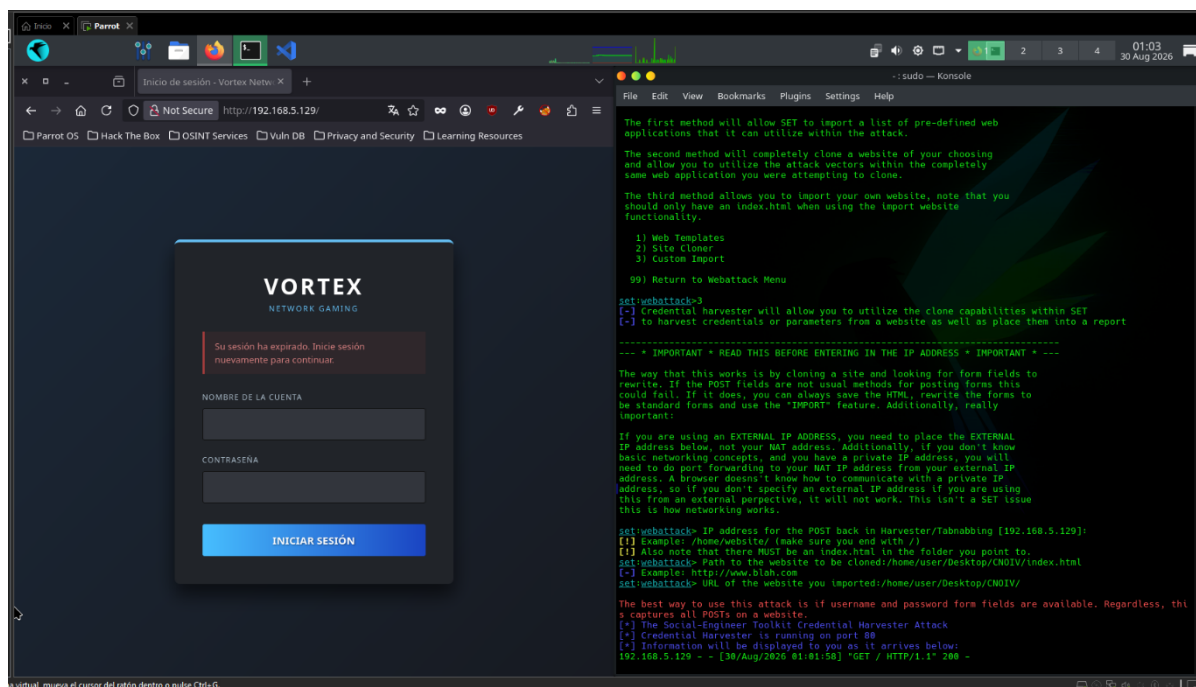
El área de seguridad informática de la empresa Vortex Gaming recibió reportes de empleados sobre un mensaje de actualización de credenciales. El enlace dirige a un portal aparentemente institucional que contiene el logotipo de la empresa, campos de autenticación y el mensaje: "Su sesión ha expirado. Inicie sesión nuevamente para continuar". Aunque visualmente es idéntico al sistema legítimo, el portal no pertenece a la empresa.

Configuración del laboratorio

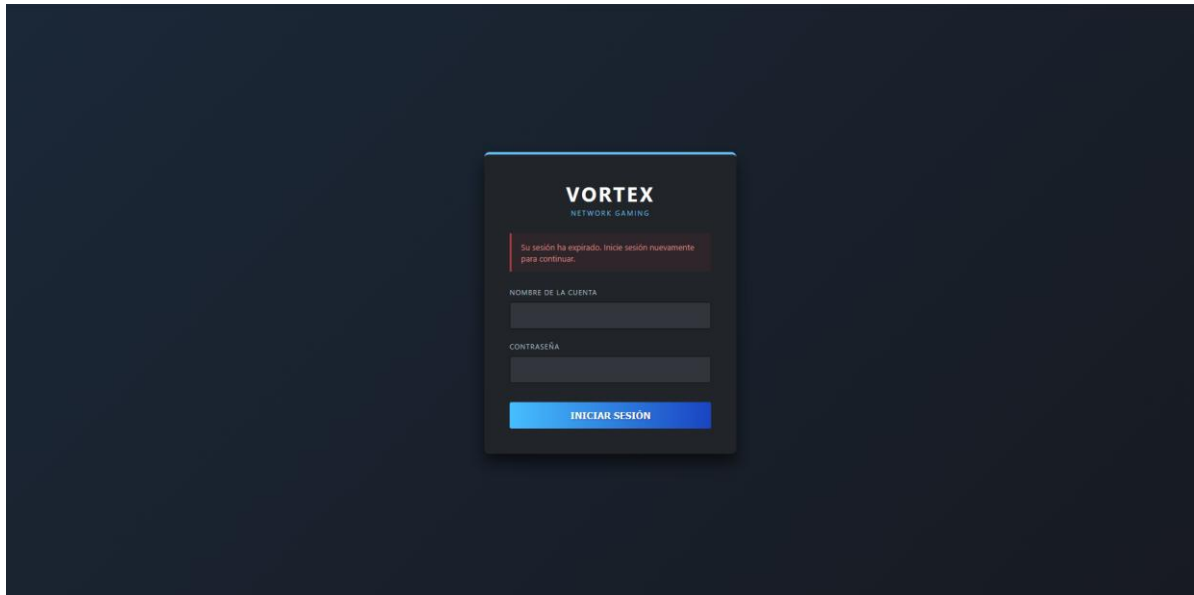
Para este escenario se utilizó VMware para virtualizar una máquina atacante con ParrotOS. Dentro de este entorno, se ejecutó la herramienta Social-Engineer Toolkit (SET) utilizando el módulo Credential Harvester Attack Method. Se seleccionó la opción "Custom Import" para cargar un archivo HTML ficticio (Vortex Network) diseñado localmente, evitando clonar portales reales.

- **¿Qué es Credential Harvester y cuál es su función en el phishing?** Es un método de ataque que aloja una página web fraudulenta en un servidor controlado por el atacante. Su función en el phishing es actuar como trampa final: interceptar y almacenar en texto plano las credenciales que la víctima introduce engañada, explotando la confianza visual del usuario.

Evidencias y descripción del funcionamiento



Descripción: Configuración inicial de Credential Harvester en SET, estableciendo el servidor local a la escucha del tráfico HTTP.

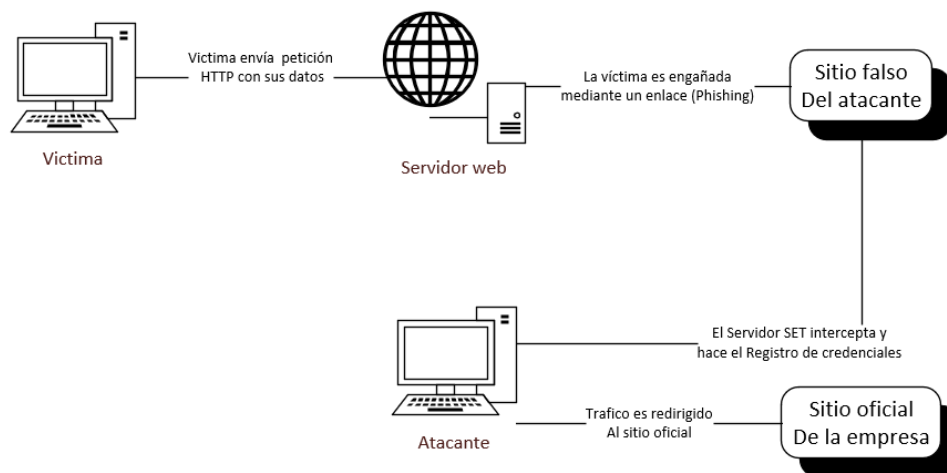


Descripción: Interfaz del portal falso desde la perspectiva de la empresa, mostrando el formulario y el mensaje de sesión expirada.

```
The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
192.168.5.129 - - [30/Aug/2026 01:01:58] "GET / HTTP/1.1" 200 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: username=D3im05@sincorreio.com
POSSIBLE PASSWORD FIELD FOUND: password=password
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```

Descripción: El servidor de SET interceptando la petición de iniciar sesión y registro correctamente las credenciales en un archivo local.

Explicación del flujo de información



Controles de Seguridad propuestos

En este ejercicio encontramos algunas cosas que podrían levantar alerta

- **URL discrepante:** El enlace utilizado fue una dirección IP local. En un entorno real, siempre se debe verificar que la URL corresponda exactamente al dominio oficial de la empresa.
- **Falta de cifrado SSL:** La dirección web utiliza HTTP en lugar de HTTPS. La advertencia de "sitio no seguro" en el navegador es una señal crítica de alerta.
- **Canal de distribución anómalo:** Si un servidor empresarial entra en mantenimiento, los departamentos de TI envían comunicados previos. Las sesiones no expiran abruptamente exigiendo un inicio de sesión desde enlaces no solicitados.
- **Ausencia de validación:** El portal falso acepta cualquier cadena de texto ingresada sin realizar una comprobación lógica del formato del correo corporativo.
- **Sentido de urgencia (Requisito 5 de la rúbrica):** El texto manipula al usuario haciéndole creer que debe actuar de inmediato porque su sesión ya expiró, evitando que analice la situación con calma.

Soluciones propuestas

1. **Autenticación Multifactor (MFA):** Bloquea el acceso no autorizado. Aunque el atacante obtenga la contraseña, la cuenta y la información permanecen seguras al requerir un segundo factor.
2. **Gestor de contraseñas:** Evitan el autocompletado automático de credenciales al detectar discrepancias entre el sitio legítimo y las URLs falsas.
3. **Filtro Anti-Spoofing:** Reduce significativamente la llegada de correos fraudulentos a las bandejas de entrada corporativas.
4. **Filtro DNS:** Bloquea las resoluciones de red hacia dominios maliciosos o que fueron creados de manera muy reciente.
5. **Capacitación continua:** Mantiene al personal actualizado sobre las nuevas tácticas de ataque, fortaleciendo la seguridad de la empresa desde el factor humano.

Conclusión

La actividad demostró lo peligroso que pueden ser los ataques de ingeniería social, comprobando que las defensas técnicas más robustas pueden ser eludidas si el usuario final es manipulado. Se comprendió que el Credential Harvester explota la confianza visual, lo que resalta la necesidad de combinar controles técnicos como MFA con concientización humana constante para mitigar estos riesgos de manera integral.

Referencias

Kaspersky Lab. (s.f.). *¿Qué es el phishing y cómo prevenirlo? Consejos para evitar estafas.* Centro de recursos de ciberseguridad. Recuperado el 30 de agosto de 2026, de <https://latam.kaspersky.com/resource-center/preemptive-safety/phishing-prevention-tips>

TrustedSec. (2026). *The Social-Engineer Toolkit (SET) - Repositorio Oficial.* GitHub. Recuperado el 30 de agosto de 2026, de <https://github.com/trustedsec/social-engineer-toolkit>